

MySQL

MySQL is an open-source SQL relational database management system developed and supported by Oracle. A database is simply a structured collection of data organized for easy use and retrieval. The database system can quickly process large amounts of data with high performance. Within the database, data storage is done in a manner to take up as little space as possible. The database is controlled using the [SQL database language](#). MySQL works according to the [client-server principle](#) and consists of a MySQL server and one or more MySQL clients. The MySQL server is the actual database management system. It takes care of data storage and distribution. The data is stored in tables with different columns, rows, and data types. These databases are often stored in a single file with the file extension `.sql`, for example, like `wordpress.sql`.

MySQL Clients

The MySQL clients can retrieve and edit the data using structured queries to the database engine. Inserting, deleting, modifying, and retrieving data, is done using the SQL database language. Therefore, MySQL is suitable for managing many different databases to which clients can send multiple queries simultaneously. Depending on the use of the database, access is possible via an internal network or the public Internet.

One of the best examples of database usage is the CMS WordPress. WordPress stores all created posts, usernames, and passwords in their own database, which is only accessible from the localhost. However, as explained in more detail in the module [Introduction to Web Applications](#), there are database structures that are distributed across multiple servers also.

MySQL Databases

MySQL is ideally suited for applications such as [dynamic websites](#), where efficient syntax and high response speed are essential. It is often combined with a Linux OS, PHP, and an Apache web server and is also known in this combination as [LAMP](#) (Linux, Apache, MySQL, PHP), or when using Nginx, as [LEMP](#). In a web hosting with MySQL database, this serves as a central instance in which content required by PHP scripts is stored. Among these are:

Headers	Texts	Meta tags	Forms
Customers	Usernames	Administrators	Moderators
Email addresses	User information	Permissions	Passwords
External/Internal links	Links to Files	Specific contents	Values

Sensitive data such as passwords can be stored in their plain-text form by MySQL; however, they are generally encrypted beforehand by the PHP scripts using secure methods such as [One-Way-Encryption](#).

MySQL Commands

A MySQL database translates the commands internally into executable code and performs the requested actions. The web application informs the user if an error occurs during processing, which various [SQL injections](#) can provoke. Often, these error descriptions contain important information and confirm, among other things, that the web application interacts with the database in a different way than the developers intended.

The web application sends the generated information back to the client if the data is processed correctly. This information can be the data extracts from a table or records needed for further processing with logins, search functions, etc. SQL commands can display, modify, add or delete rows in tables. In addition, SQL can also change the structure of tables, create or delete relationships and indexes, and manage users.

MariaDB, which is often connected with MySQL, is a fork of the original MySQL code. This is because the chief developer of MySQL left the company MySQL AB after it was acquired by Oracle and developed another open-source SQL database management system based on the source code of MySQL and called it MariaDB.

Default Configuration

The management of SQL databases and their configurations is a vast topic. It is so large that entire professions, such as database administrator, deal with almost nothing but databases. These structures become very large quickly, and their planning can become complicated. Among other things, DB management is a core competency for software developers but also information security analysts. To cover this area completely would go beyond the scope of this module. Therefore, we recommend setting up a MySQL/MariaDB instance to experiment with the various configurations to understand the available functionality and configuration options better. Let us have a look at the default configuration of MySQL.

Default Configuration

Default Configuration

```
dbcyp0n@htb[/htb]$ sudo apt install mysql-server -y
dbcyp0n@htb[/htb]$ cat /etc/mysql/mysql.conf.d/mysqld.cnf | grep -v "#" | sed -r '/^\s*$/d'

[client]
port                = 3306
socket              = /var/run/mysqld/mysqld.sock

[mysqld_safe]
pid-file            = /var/run/mysqld/mysqld.pid
socket              = /var/run/mysqld/mysqld.sock
nice                = 0

[mysqld]
skip-host-cache
skip-name-resolve
user                = mysql
pid-file            = /var/run/mysqld/mysqld.pid
socket              = /var/run/mysqld/mysqld.sock
port                = 3306
basedir             = /usr
datadir             = /var/lib/mysql
tmpdir              = /tmp
lc-messages-dir     = /usr/share/mysql
explicit_defaults_for_timestamp

symbolic-links=0

!includedir /etc/mysql/conf.d/
```

Dangerous Settings

Many things can be misconfigured with MySQL. We can look in more detail at the [MySQL reference](#) to determine which options can be made in the server configuration. The main options that are security-relevant are:

Settings	Description
user	Sets which user the MySQL service will run as.
password	Sets the password for the MySQL user.
admin_address	The IP address on which to listen for TCP/IP connections on the administrative network interface.
debug	This variable indicates the current debugging settings

Settings	Description
sql_warnings	This variable controls whether single-row INSERT statements produce an information string if warnings occur.
secure_file_priv	This variable is used to limit the effect of data import and export operations.

The settings `user`, `password`, and `admin_address` are security-relevant because the entries are made in plain text. Often, the rights for the configuration file of the MySQL server are not assigned correctly. If we get another way to read files or even a shell, we can see the file and the username and password for the MySQL server. Suppose there are no other security measures to prevent unauthorized access. In that case, the entire database and all the existing customers' information, email addresses, passwords, and personal data can be viewed and even edited.

The `debug` and `sql_warnings` settings provide verbose information output in case of errors, which are essential for the administrator but should not be seen by others. This information often contains sensitive content, which could be detected by trial and error to identify further attack possibilities. These error messages are often displayed directly on web applications. Accordingly, the SQL injections could be manipulated even to have the MySQL server execute system commands. This is discussed and shown in the module [SQL Injection Fundamentals](#) and [SQLMap Essentials](#).

Footprinting the Service

There are many reasons why a MySQL server could be accessed from an external network. Nevertheless, it is far from being one of the best practices, and we can always find databases that we can reach. Often, these settings were only meant to be temporary but were forgotten by the administrators. This server setup could also be used as a workaround due to a technical problem. Usually, the MySQL server runs on `TCP port 3306`, and we can scan this port with `Nmap` to get more detailed information.

Scanning MySQL Server

Scanning MySQL Server

```
dbcyph0n@htb[/htb]$ sudo nmap 10.129.14.128 -sV -sC -p3306 --script mysql*

Starting Nmap 7.80 ( https://nmap.org ) at 2021-09-21 00:53 CEST
Nmap scan report for 10.129.14.128
Host is up (0.00021s latency).

PORT      STATE SERVICE      VERSION
3306/tcp  open  nagios-nrpe Nagios NRPE
| mysql-brute:
|   Accounts:
|     root:<empty> - Valid credentials
|_ Statistics: Performed 45010 guesses in 5 seconds, average tps: 9002.0
|_mysql-databases: ERROR: Script execution failed (use -d to debug)
|_mysql-dump-hashes: ERROR: Script execution failed (use -d to debug)
| mysql-empty-password:
|_ root account has empty password
| mysql-enum:
|   Valid usernames:
|     root:<empty> - Valid credentials
|     netadmin:<empty> - Valid credentials
|     guest:<empty> - Valid credentials
|     user:<empty> - Valid credentials
|     web:<empty> - Valid credentials
|     sysadmin:<empty> - Valid credentials
|     administrator:<empty> - Valid credentials
|     webadmin:<empty> - Valid credentials
|     admin:<empty> - Valid credentials
|     test:<empty> - Valid credentials
|_ Statistics: Performed 10 guesses in 1 seconds, average tps: 10.0
| mysql-info:
|   Protocol: 10
|   Version: 8.0.26-0ubuntu0.20.04.1
|   Thread ID: 13
|   Capabilities flags: 65535
|   Some Capabilities: SupportsLoadDataLocal, SupportsTransactions, Speaks41Protocol0ld, LongPassword, DontAllowD
|   Status: Autocommit
|   Salt: YTSgMfqvx\x0F\x7F\x16\&\x1EAek>0
|_ Auth Plugin Name: caching_sha2_password
|_mysql-users: ERROR: Script execution failed (use -d to debug)
|_mysql-variables: ERROR: Script execution failed (use -d to debug)
|_mysql-vuln-cve2012-2122: ERROR: Script execution failed (use -d to debug)
MAC Address: 00:00:00:00:00:00 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.21 seconds
```

As with all our scans, we must be careful with the results and manually confirm the information obtained because some of the information might turn out to be a false-positive. This scan above is an excellent example of this, as we know for a fact that the target MySQL server does not use an empty password for the user `root`, but a fixed password. We can test this with the following command:

Interaction with the MySQL Server

Interaction with the MySQL Server

```
dbcyph0n@htb[/htb]$ mysql -u root -h 10.129.14.132

ERROR 1045 (28000): Access denied for user 'root'@'10.129.14.1' (using password: NO)
```

For example, if we use a password that we have guessed or found through our research, we will be able to log in to the MySQL server and execute some commands.

Interaction with the MySQL Server

```
dbcyp0n@htb[/htb]$ mysql -u root -pP4SSw0rd -h 10.129.14.128
```

```
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 150165
Server version: 8.0.27-0ubuntu0.20.04.1 (Ubuntu)
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```

```
MySQL [(none)]> show databases;
```

```
+-----+
| Database          |
+-----+
| information_schema |
| mysql              |
| performance_schema |
| sys                |
+-----+
4 rows in set (0.006 sec)
```

```
MySQL [(none)]> select version();
```

```
+-----+
| version()          |
+-----+
| 8.0.27-0ubuntu0.20.04.1 |
+-----+
1 row in set (0.001 sec)
```

```
MySQL [(none)]> use mysql;
```

```
MySQL [mysql]> show tables;
```

```
+-----+
| Tables_in_mysql    |
+-----+
| columns_priv        |
| component            |
| db                  |
| default_roles        |
| engine_cost          |
| func                |
| general_log          |
| global_grants        |
| gtid_executed         |
| help_category        |
| help_keyword         |
| help_relation        |
| help_topic           |
| innodb_index_stats    |
| innodb_table_stats    |
| password_history      |
| ...SNIP...           |
| user                 |
+-----+
37 rows in set (0.002 sec)
```

If we look at the existing databases, we will see several already exist. The most important databases for the MySQL server are the [system schema](#) (`sys`) and [information schema](#) (`information_schema`). The system schema contains tables, information, and metadata necessary for management. More about this database can be found in the [reference manual](#) of MySQL.

Interaction with the MySQL Server

```
mysql> use sys;
mysql> show tables;

+-----+
| Tables_in_sys |
+-----+
| host_summary |
| host_summary_by_file_io |
| host_summary_by_file_io_type |
| host_summary_by_stages |
| host_summary_by_statement_latency |
| host_summary_by_statement_type |
| innodb_buffer_stats_by_schema |
| innodb_buffer_stats_by_table |
| innodb_lock_waits |
| io_by_thread_by_latency |
| ...SNIP... |
| x$waits_global_by_latency |
+-----+

mysql> select host, unique_users from host_summary;

+-----+-----+
| host | unique_users |
+-----+-----+
| 10.129.14.1 | 1 |
| localhost | 2 |
+-----+-----+
2 rows in set (0,01 sec)
```

The `information schema` is also a database that contains metadata. However, this metadata is mainly retrieved from the `system schema` database. The reason for the existence of these two is the ANSI/ISO standard that has been established. `System schema` is a Microsoft system catalog for SQL servers and contains much more information than the `information schema`.

Some of the commands we should remember and write down for working with MySQL databases are described below in the table.

Command	Description
<code>mysql -u <user> -p<password> -h <IP address></code>	Connect to the MySQL server. There should not be a space between the '-p' flag, and the password.
<code>show databases;</code>	Show all databases.
<code>use <database>;</code>	Select one of the existing databases.
<code>show tables;</code>	Show all available tables in the selected database.
<code>show columns from <table>;</code>	Show all columns in the selected database.
<code>select * from <table>;</code>	Show everything in the desired table.
<code>select * from <table> where <column> = "<string>";</code>	Search for needed <code>string</code> in the desired table.

We must know how to interact with different databases. Therefore, we recommend installing and configuring a MySQL server on one of our VMs for experimentation. There is also a widely covered `security issues` section in the reference manual that covers best practices for securing MySQL servers. We should use this when setting up our MySQL server to understand better why something might not work.

VPN Servers

 Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

Waiting to start..

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)



Cheat Sheet



Download VPN Connection
File

+ 1

Enumerate the MySQL server and determine the version in use. (Format: MySQL X.X.XX)

MySQL 8.0.27



Submit

+ 1

During our penetration test, we found weak credentials "robin:robin". We should try these against the MySQL server. What is the email address of the customer "Otto Lang"?

ultrices@google.htb



Submit

← Previous

Next →

✓ Mark Complete & Next

 Cheat Sheet
 Resources
 Go to Questions

Table of Contents

Introduction

Enumeration Principles	✓
Enumeration Methodology	✓

Infrastructure Based Enumeration

Domain Information	✓
Cloud Resources	✓
Staff	✓

Host Based Enumeration

 FTP	✓
 SMB	✓
 NFS	✓
 DNS	✓
 SMTP	✓
 IMAP / POP3	✓
 SNMP	✓
 MySQL	✓
 MSSQL	✓
 Oracle TNS	
 IPMI	

Remote Management Protocols

Linux Remote Management Protocols	
Windows Remote Management Protocols	

Skills Assessment

 Footprinting Lab - Easy	
 Footprinting Lab - Medium	
 Footprinting Lab - Hard	

My Workstation

OFFLINE

 Start Instance

 / 1 spawns left